

Unprotected admin functionality

Topic: Authorization (Access Control) | Difficulty: Apprentice

Description

The administrative panel is accessible without any authentication. The panel path is disclosed in the application's robots.txt file. Any user who discovers this path can navigate directly to the admin panel and perform privileged actions such as deleting user accounts.

Steps to Exploit

1. Navigate to /robots.txt on the target application.
2. Observe the Disallow directive revealing the admin panel path.
3. Navigate directly to /administrator-panel.
4. Observe full admin functionality is accessible with no authentication prompt.
5. Use the admin panel to delete user 'carlos' to complete the lab.

Proof of Concept

robots.txt contents:

```
User-agent: *  
Disallow: /administrator-panel
```

Direct admin access:

```
GET /administrator-panel HTTP/1.1  
Host: TARGET  
  
-> 200 OK (no auth required)
```

Impact

- Unauthenticated access to all administrative functionality.
- Ability to delete, modify, or create any user account.
- Full application compromise without requiring valid credentials.
- Disclosure of administrative features to any internet user.

Mitigation / Remediation

1. Enforce server-side authentication and authorization checks on all admin endpoints.
2. Do not rely on URL obscurity or robots.txt as a security control.
3. Implement role-based access control (RBAC) for all privileged operations.
4. Audit all endpoints for missing access control enforcement.

CVSS Score

CVSS v3.1: 9.1 (Critical)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

CVSS Justification

- Attack Vector: Network - direct URL navigation.
- Attack Complexity: Low - robots.txt lookup then URL access.
- Privileges Required: None.
- User Interaction: None.
- Confidentiality / Integrity: High - full admin panel access.
- Availability: None.